🌐 Module 06: API and Java Web Token Penetration Testing

```
# Exercise 08: Exploiting Hidden API Functionality Exposure to Gather Information on the Target App
```

Scenario

Restful web applications frequently deploy interactive API documentation tools (such as Swagger UI or OpenAPI specs) during development to assist frontend developers. When production deployments leave API documentation endpoints (**/api-docs/**) publicly accessible, unauthorized users can discover hidden, internal, or administrative endpoints (**/api/v1/info**).

The **Damn Vulnerable Web Services (DVWS) Node** platform exposes interactive OpenAPI/Swagger definitions. By inspecting endpoint specifications and querying system information endpoints via HTTP GET requests in Burp Repeater, security analysts can retrieve comprehensive environment metadata, internal service routes, and application configuration details.

In this exercise, we initialize `dvws-node` on Ubuntu, access Swagger UI on port 8080 (**http://192.168.0.19:8080/api-docs/**), inspect internal system routes (`/api/v1/info`), intercept API requests in Burp Suite, modify request headers, and verify system information extraction with a response Content-Length of **21654** bytes.

Objective

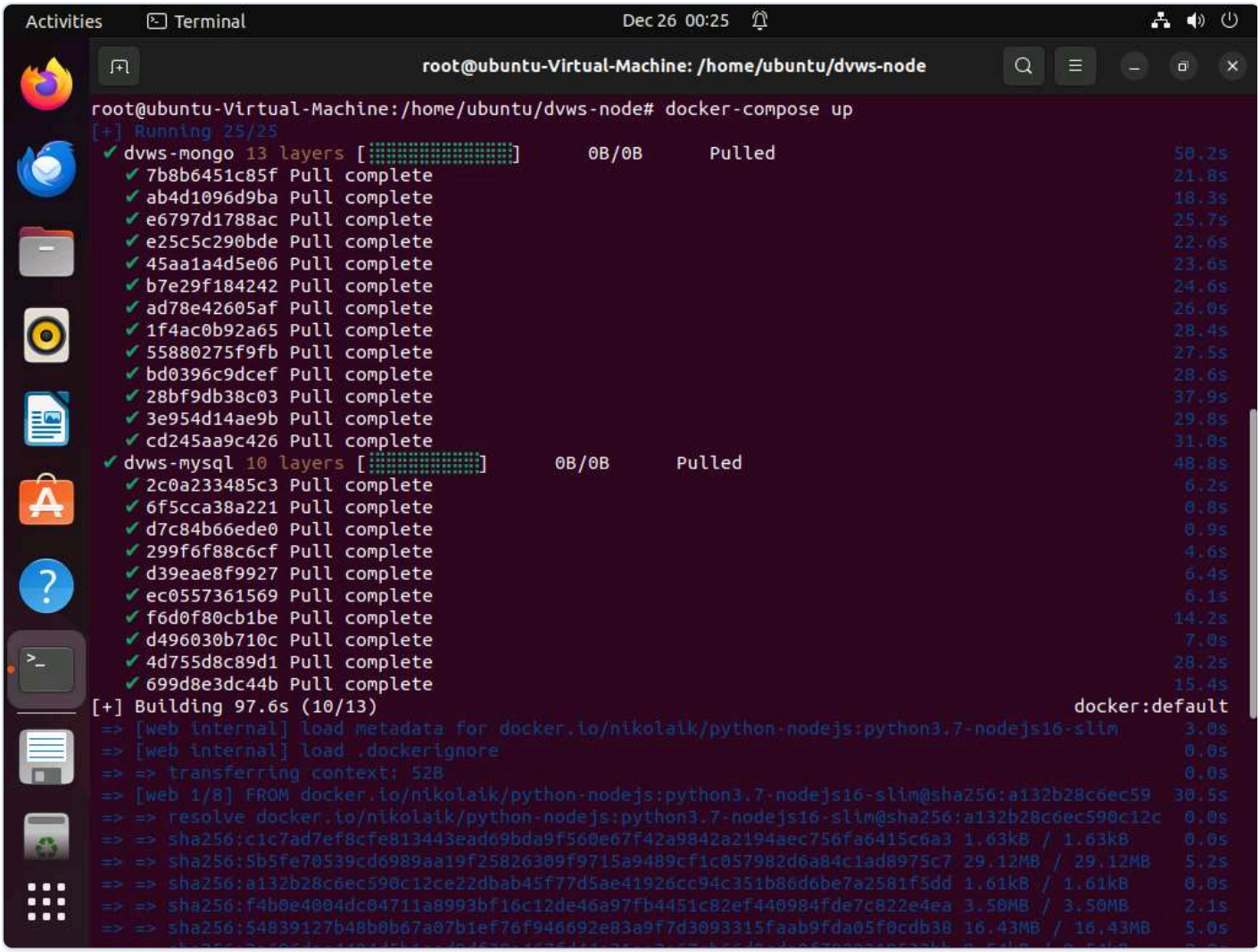
The objective of this lab is to help students learn how to:
- Deploy and execute containerized Node.js vulnerable web service platforms (`dvws-node`)
- Enumerate exposed OpenAPI / Swagger UI interactive documentation portals (**/api-docs/**)
- Identify hidden system metadata and application information endpoints (**/api/v1/info**)
- Intercept, modify, and replay HTTP GET API requests using Burp Suite Repeater
- Validate system information disclosure and record exact response HTTP header parameters (**21654**)

Task 1: Exploit Hidden API Endpoints and Extract System Metadata

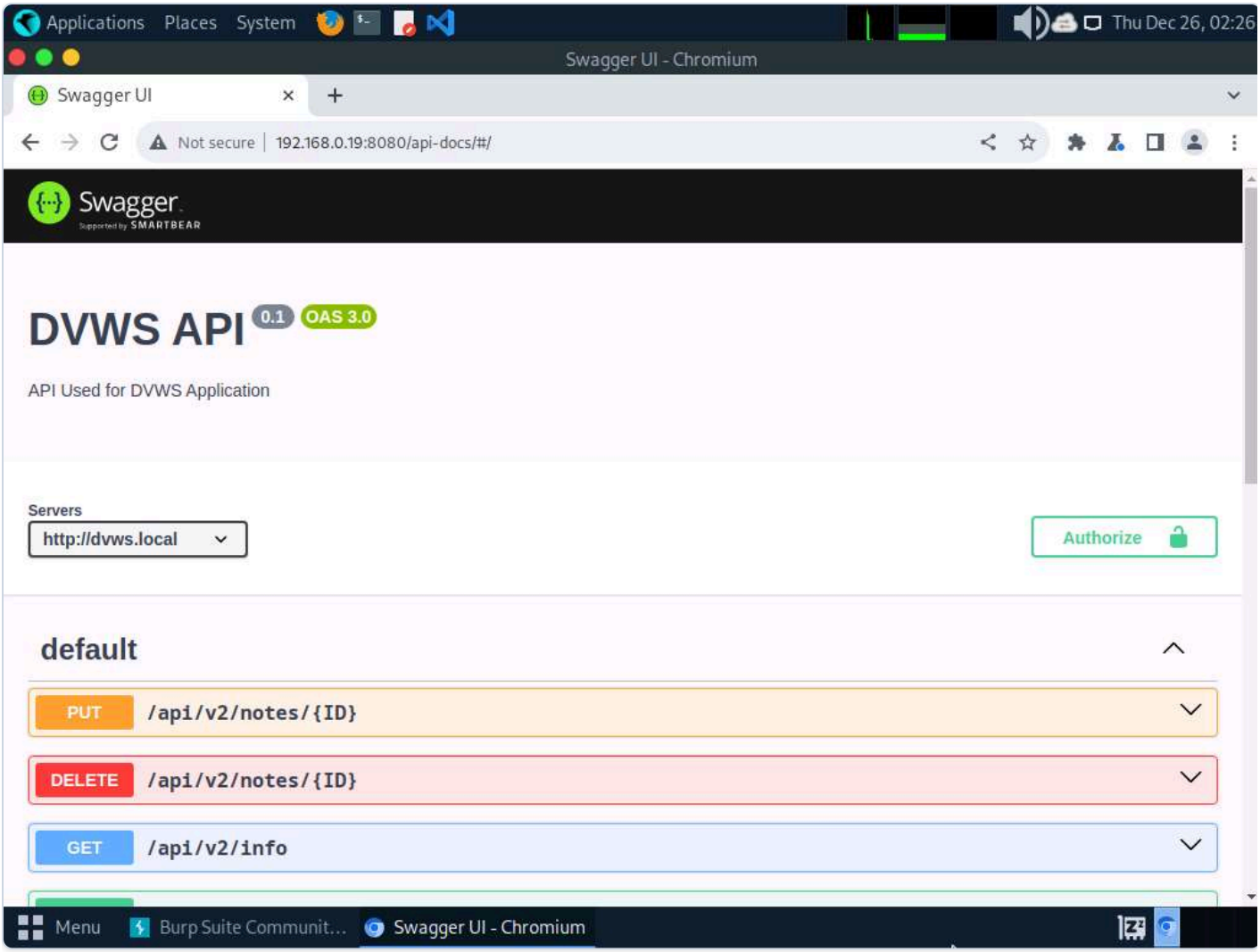
In this task, we initialize `dvws-node` on Ubuntu, navigate to Swagger UI on Parrot Security, capture system info GET requests in Burp Suite, modify Target connection settings in Repeater, and execute requests to extract system configuration details.

Lab Tasks

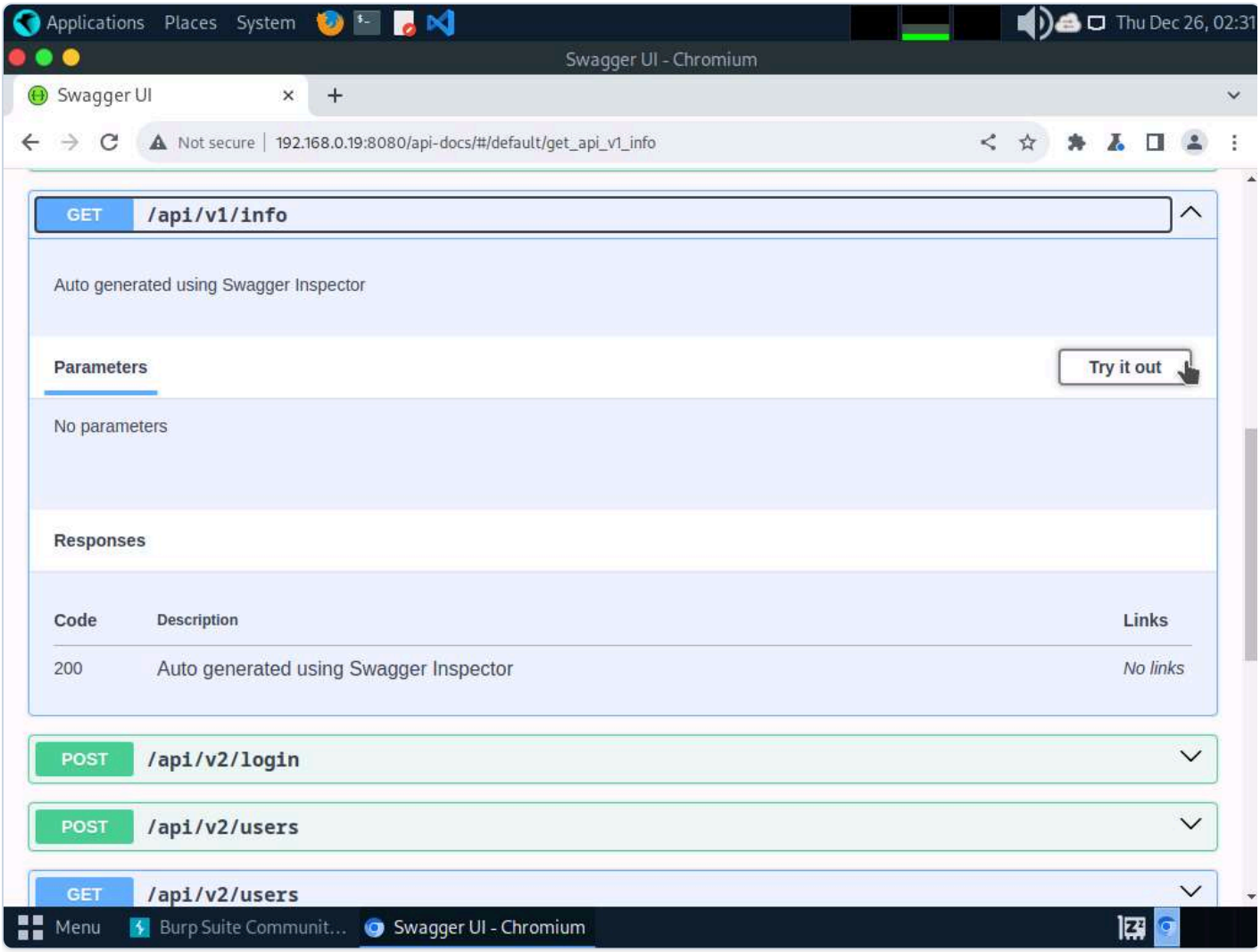
1. Switch to **Ubuntu** (**ubuntu** / **toor**), open a root terminal (**sudo su**), and navigate to the application directory:
   cd dvws-node
2. Launch the application stack:
   docker-compose up

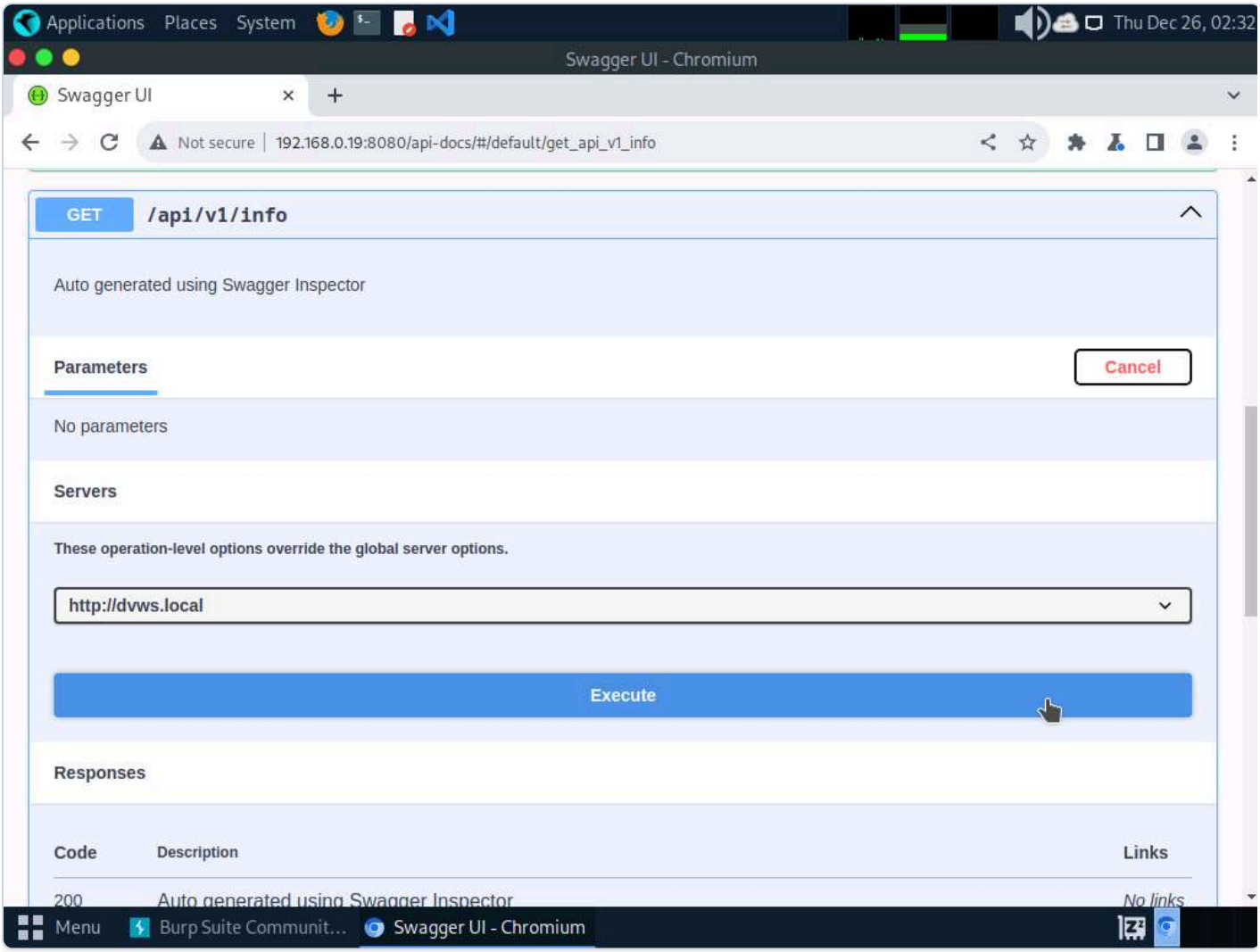


1. Switch to **Parrot Security** (**pentester** / **toor**). Launch **Burp Suite Community Edition**, turn **Intercept is OFF**, and click **Open browser**.
2. In Burp's Chromium browser, open **http://192.168.0.19:8080/api-docs/** to access the Swagger UI documentation.
3. In Burp Suite, click **Forward** to ensure all background documentation resources load successfully.

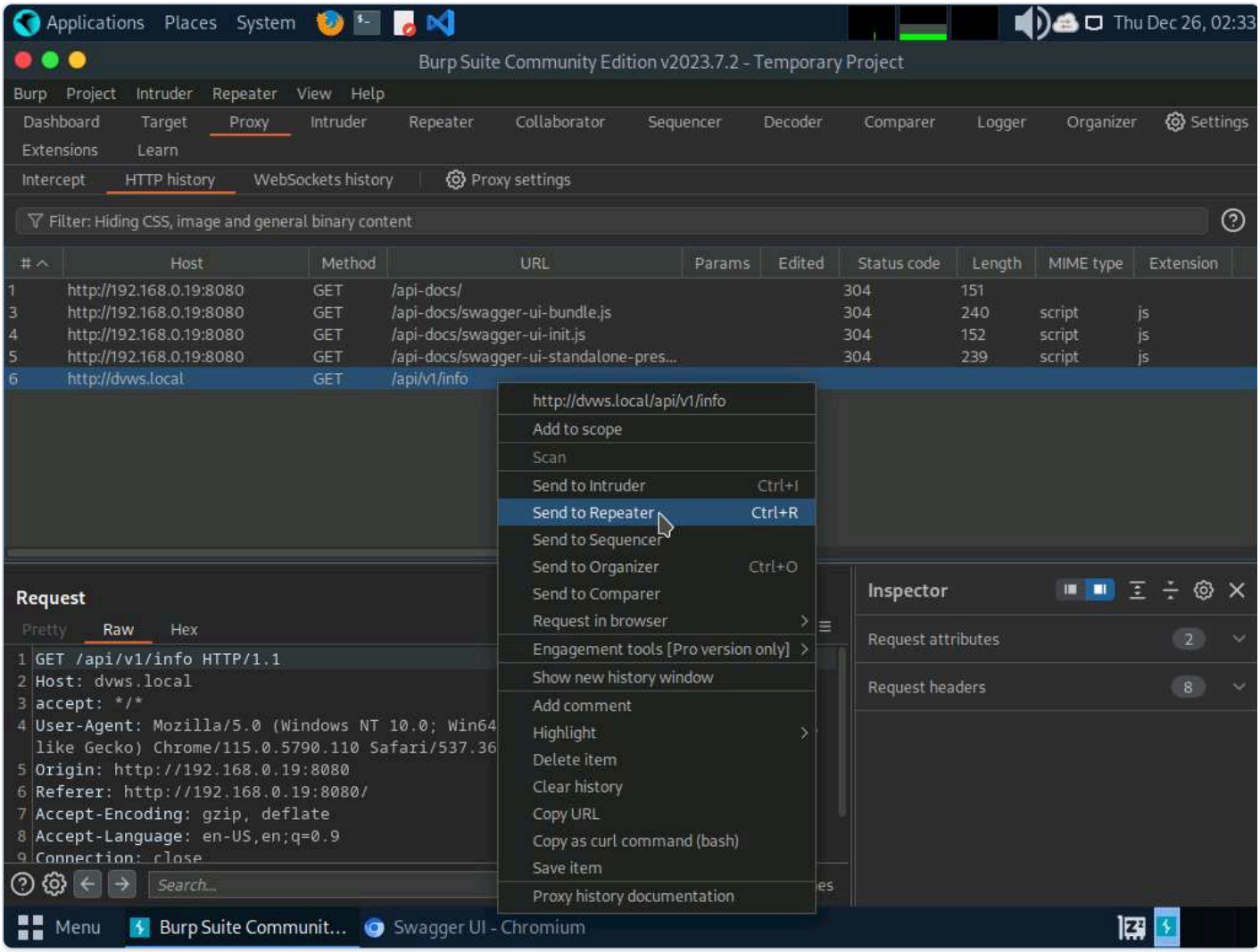


1. In the Swagger UI documentation page, scroll down to the **/api/v1/info** section.
2. Click **Try it out** and then click **Execute**.
3. Switch to Burp Suite and click **Forward** for any held requests.


Applications Places System
Thu Dec 26, 02:31
Swagger UI - Chromium
Swagger UI
Not secure | 192.168.0.19:8080/api-docs/#/default/get_api_v1_info
GET /api/v1/info
Auto generated using Swagger Inspector
Parameters
Try it out
No parameters
Responses
Code Description Links
200 Auto generated using Swagger Inspector No links
POST /api/v2/login
POST /api/v2/users
GET /api/v2/users
Menu
Burp Suite Communit...
Swagger UI - Chromium

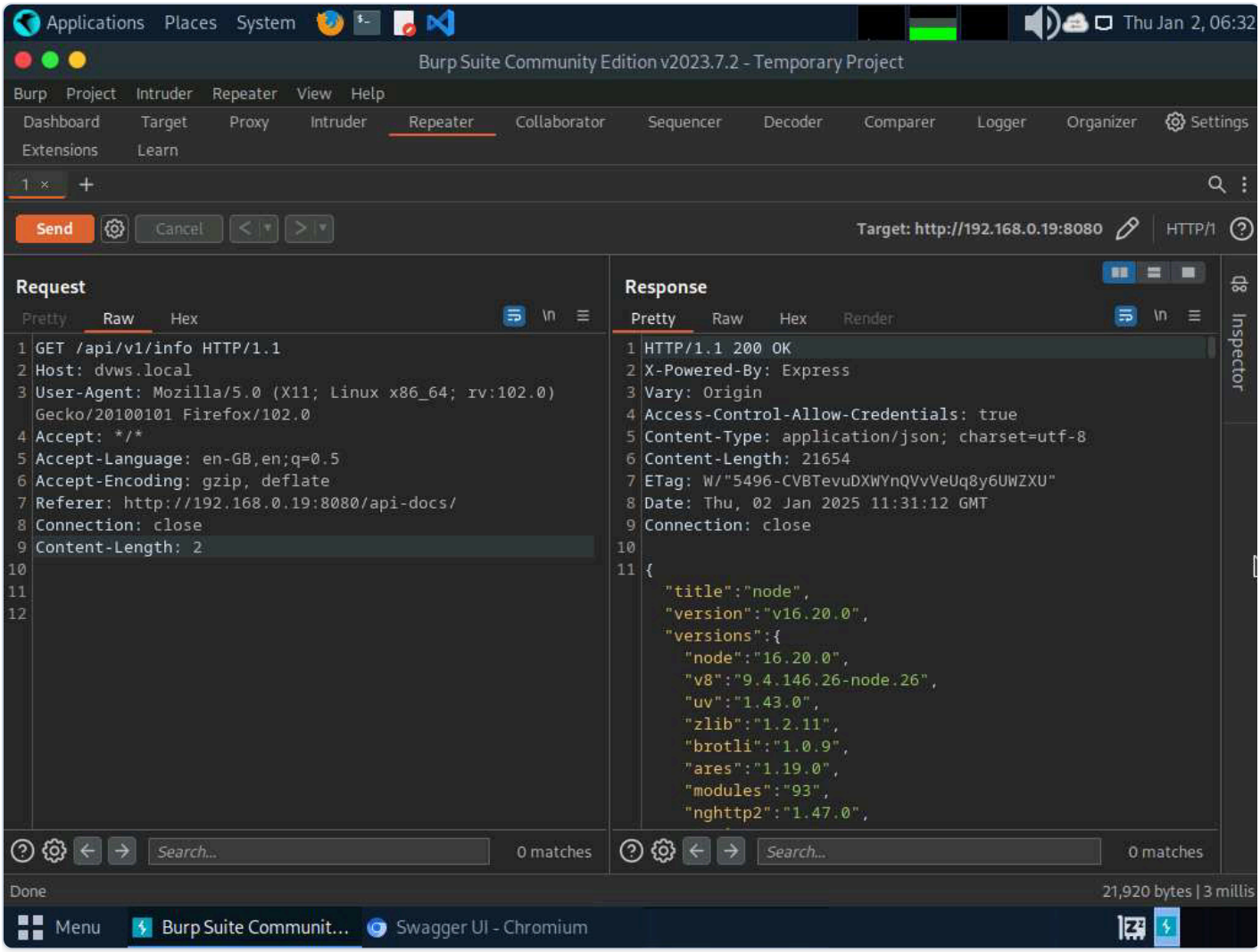


1. Open **Proxy** $
   ightarrow$ **HTTP history** tab in Burp Suite, locate the GET request targeting **/api/v1/info**, right-click, and select **Send to Repeater**.



1. Navigate to the **Repeater** tab. Click the pencil icon beside **Target** in the top-right corner, enter Host: **192.168.0.19** and Port: **8080**, then click **OK**.

2. In the Raw request editor, modify the GET request to query the system info documentation endpoint directly and click **Send**.



1. Inspect the HTTP 200 OK response containing environment parameters and application metadata.
2. Note that the Content-Length header of the modified response is: **21654**.
3. Close all browser and Burp Suite windows.

This concludes the lab exercise.

> **IMPORTANT:** ❓ **Question 6.8.1.1** On the Ubuntu machine, launch the DVWS application. Utilize the Parrot Security machine to gather detailed information about the application by modifying the GET request. Record the Content-Length of the modified request as the final answer. [!SUCCESS] ✅
> **Answer:** **21654**